impacting the rest of the account. OAuth allows for delegated access: controlled, revocable, and limited to exactly what the person consents to.

> ***NOTE***
>
> All references to *OAuth* refer to the newer OAuth 2.0 protocol, not OAuth 1.0a. You might still come across OAuth-1.0a-protected APIs, but OAuth 1.0a should not be used for new projects.

11.2.1 The OAuth protocol and roles

The OAuth protocol defines four main actors:

- **Resource Owner**. The individual who owns the data or resources. In ACME's case, Kate is a resource owner; she manages documents and workspaces on the Customer Collaboration platform.
- **Client**. The application requesting access to the resource owner's data. Kate wants to use BI Explorer, a reporting tool, to analyze her Customer Collaboration data. BI Explorer is the client.
- **Authorization Server**. The service that authenticates the resource owner and issues tokens to the client. At ACME, this role is fulfilled by the Customer Authentication Service, which verifies Kate's identity and provides OAuth tokens that encode which scopes she approved.
- **Resource Server**. The API that hosts the protected resources and responds to requests. For ACME, the Customer Collaboration API is the resource server, providing data about Kate's documents and workspaces.

Figure 11.4 illustrates these four roles in Kate's scenario. Kate (the resource owner) uses BI Explorer (the client). BI Explorer requests access through ACME's Customer Authentication Service (the authorization server), which issues a token if Kate consents. That token can then be presented to the Customer Collaboration API (the resource server), which ultimately provides data but only after evaluating Cedar policies to determine what is permitted.